

DOSSIER DE PRÉSENTATION TECHNIQUE & STRATÉGIQUE

MERIDIAN CYBER DEFENSE OS

Serious Game d'Incident & Cyber Range d'Entreprise (30 Min)

Simulation réaliste de crise cyber : du hameçonnage ciblé (phishing RH) au rançongiciel LockBit 3.0, avec gouvernance de crise, répliques d'outils d'entreprise réels et démonstration cinématique sans défilement.

RÉPONSE AUX EXIGENCES DU CHEF DE DÉPARTEMENT :

- **Remplacement d'une vidéo passive** : Plateforme active, vivante, où les participants prennent des décisions en direct.
- **Environnement et outils authentiques** : Reproduction fidèle de Microsoft Outlook 365, Splunk SIEM, Windows Server 2022, Microsoft Entra ID, Veeam Backup et Hotline DG.
- **Mode Démo Auto Cinématique (« Zero-Scroll »)** : Démonstration fluide qui alterne explication (« ce qui va se passer ») et exécution réelle sous les yeux du public, sans toucher la souris.
- **Doctrine officielle ANSSI** : Respect rigoureux de la chaîne d'incident (Alerter, Isoler sans éteindre, Refuser de payer, Contrôler les sauvegardes Air-Gap, Communiquer).

1. Les 7 Simulateurs d'Infrastructure d'Entreprise

Plutôt que des maquettes simplistes, la plateforme intègre 7 modules reproduisant fidèlement les véritables consoles utilisées par les collaborateurs, le SOC, les administrateurs et la direction :

1. Microsoft Outlook 365

COLLABORATEUR

Messagerie d'entreprise avec ruban Office, boîte de réception, et détection de typosquatting (entreprise-support.com).

- **Inspecteur RFC 822** : Vérification SPF (Fail), DKIM et DMARC.
- **Mode Bac à Sable Word** : Document avec bandeau jaune et macro VBA.
- **Bouton PhishAlarm** : Signalement direct au SOC (+2 pts).

2. Splunk SIEM & SentinelOne EDR

SOC / BLUE TEAM

Console d'analyse de télémétrie SOC avec ingestion en direct (EPS) et filtrage sévérité (P1 Critique, P2 Alerte).

- **Barre de requête SPL** : Recherche sur les logs EDR et index d'attaque.
- **Arbre des processus** : OUTLOOK → WINWORD → powershell → beacon.exe.
- **Actions RTR** : Confinement réseau, arrêt de processus PID, dump RAM.

3. Radar Topologie Réseau Animé

SUPERVISION RÉSEAU

Schéma vectoriel SVG dynamique montrant la topologie physique (Postes, Pare-feu, Serveurs, Dépôt Backup).

- **Faisceaux laser de paquets** : Visualisation des flux C2 et rebond SMB.
- **Coupure instantanée** : Les flux s'arrêtent net lors du confinement.
- **Fiches d'équipement** : Rôles, adresses IP, VLAN et ports ouverts.

4. Windows Server 2022 & LockBit

SERVEUR DE FICHIERS

Explorateur Windows des partages réseau \\FS-CORP-01\Partages avec fichiers chiffrés en .locked.

- **Bloc-notes Windows** : Affichage de .README_LOCKED_RESTORE.txt.
- **Extorsion 15 BTC** : Message pirate avec modal plein écran réaliste.
- **Matrice ANSSI** : Interdiction collégiale absolue de paiement.

5. Microsoft Entra ID (Azure AD)

IDENTITÉS & IAM

Centre d'administration des identités cloud avec historique des connexions et géolocalisation.

- **Détection MFA Fatigue** : 47 notifications push nocturnes à 03h14.
- **Révocation des sessions** : Déconnexion forcée des tokens usurpés.
- **Renforcement FIDO2** : Imposition de clés matérielles.

6. Veeam Backup v12 (Air-Gap)

RÉSILIENCE & REPRISE

Console de sauvegarde étanche avec dépôt durci Linux et snapshots immuables (WORM).

- **Contrôle d'intégrité SHA256** : Audit des blocs avec barre de chargement.
- **Restauration hermétique** : Reconstitution en bac à sable quarantaine.
- **Garantie de non-réinfection** : Empêche de restaurer sur réseau infecté.

7. Centre de Crise : Hotline Direction Générale & Fuite WhatsApp

GOUVERNANCE & MÉDIAS

Gestion de la pression humaine et politique : le Directeur Général appelle en urgence, tandis qu'une photo de la rançon fuite sur un groupe WhatsApp et qu'un journaliste financier exige une interview.

📞 **Hotline DG avec Forme d'Onde** : Dialogue interactif, voix synthétisée, arbitrage entre calme factuel (+2 pts) ou promesses inconsidérées (-2 pts).

💬 **Gestion Médiatique** : Copie du communiqué officiel validé par la cellule de crise et interdiction stricte de répondre en solo à la presse.

2. Le Mode Démo Auto Cinématique (« Zero-Scroll Auto-Director »)

Pour captiver une salle ou un comité de direction sans avoir à manipuler la souris ou faire défiler la page (scroll), la plateforme propose un orchestrateur cinématique plein écran :

[LE CYCLE EN DEUX TEMPS DE CHAQUE ÉTAPE // AUTOMATISÉ À 100%]

 **PHASE 1 : BRIEFING (« CE QUI VA SE PASSER »)**
Fiche explicative plein écran avec l'étape, le TTP MITRE, la jauge de gravité de la menace (0 à 98%), et le **Triple Regard Cyber** (Salarié / Hacker / SOC). Compte à rebours automatique.

 **PHASE 2 : EXÉCUTION RÉELLE EN DIRECT**
L'écran bascule automatiquement et affiche le véritable outil en plein écran sans défilement (Outlook, Splunk, Windows Server, etc.) et exécute l'action clé en direct avec effets sonores Web Audio.

Le « Triple Regard Cyber » : Vulgarisation Instantanée pour Tous les Publics

 **1. Vue Salarié**
Karim (Compta)
Ce que voit l'utilisateur : courriel RH pressant, clic sur « Activer le contenu », puis ralentissement inexpliqué du poste.

 **2. Sous le Capot**
C2 185.22.14.89 (Bulgarie)
Ce qui se passe : la macro lance un PowerShell invisible, installe une balise C2, énumère le réseau et chiffre en AES-256.

 **3. Vue SOC / EDR**
Sara (Analyste L2)
Ce que détectent les sondes : corrélation SIEM, alarme prioritaire sur le processus suspect et isolement réseau immédiat.

Chronologie des 7 Étapes de la Démonstration Automatisée

ÉTAPE	HEURE	TITRE DU SCÉNARIO	OUTIL D'EXÉCUTION RÉEL	TTP MITRE	GRAVITÉ
STG-01	09h15	Hameçonnage Ciblé (Phishing RH) & Macro	Microsoft Outlook 365 & Word	T1566.001	25 %
STG-02	09h20	Alerte EDR, Arbre de Processus & Canal C2	Splunk SIEM Enterprise & EDR	T1059.001	55 %
STG-03	09h25	Propagation Latérale SMB vers Serveurs	Radar Réseau (Flux Laser SVG)	T1021.002	75 %
STG-04	09h40	Chiffrement Massif LockBit & Note de Rançon	Windows Server 2022 (.locked)	T1486	98 %
STG-05	09h45	Hotline DG, Arbitrage Crise & Fuite WhatsApp	Hotline Téléphonique & WhatsApp	ISO 27035	80 %
STG-06	09h55	Sauvegardes Immuables WORM & Reprise	Veeam Backup & Replication v12	Air-Gap	30 %
STG-07	10h00	Maîtrise de l'Incident & Débriefing 5 Réflexes	Cockpit Débriefing & Bilan (+12 pts)	RETEX	10 %

3. Déroulé de l'Exercice (30 Minutes Chrono)

L'exercice est structuré pour tenir exactement en 30 minutes, selon le minutage pédagogique attendu par le chef de département :

09h00 · Cadrage & Répartition des Équipes (3 minutes)

Introduction

Explication des règles, objectifs pédagogiques, présentation de l'entreprise fictive Meridian et constitution des équipes d'apprenants (Blue Team, Direction, Métier).

09h15 · Scénario 1 : Le Hameçonnage (5 minutes)

RÉFLEXES 1 & 2

Situation : Karim clique sur la pièce jointe. Le PC ralentit. **Action :** Alerter immédiatement le support/SOC et isoler le poste sans l'éteindre afin de préserver la RAM.

09h25 · Scénario 2 : L'Alerte SOC & Propagation (5 minutes)

RÉFLEXE 3

Situation : L'EDR sonne. Connexion suspecte vers l'IP bulgare et rebonds SMB. **Action :** Isolement EDR des 3 postes compromis, blocage de l'IP C2 au pare-feu et qualification d'étendue.

09h40 · Scénario 3 : Le Chiffrement Rançongiciel (5 minutes)

RÉFLEXE 4

Situation : 15 BTC exigés par LockBit 3.0. Tous les fichiers métiers sont bloqués. **Action :** Cellule de crise, **refus formel de payer** (doctrine ANSSI) et audit des sauvegardes Air-Gap.

09h50 · Scénario 4 : La Crise & Communication (4 minutes)

RÉFLEXE 5

Situation : Fuite sur WhatsApp et appel journaliste. **Action :** Diffusion exclusive du communiqué officiel validé par la Direction et le Juridique.

10h00 · Débriefing, Retex & Ancrage des 5 Réflexes (8 minutes)

SYNTHÈSE

Analyse des scores obtenus, débriefing des erreurs évitées, remise de l'attestation et mémorisation des 5 réflexes vitaux.

LES 5 RÉFLEXES DE CYBERDÉFENSE ANCRÉS LORS DE LA FORMATION :

1. DÉTECTER : Savoir identifier les signaux faibles (typosquatting, macro, lenteur).

2. ALERTER : Prévenir sans délai le support et le SOC ; ne jamais cacher l'erreur.

3. ISOLER : Débrancher le câble réseau / Wi-Fi, mais ne jamais éteindre le PC.

4. DÉCIDER : Gouvernance collégiale et interdiction stricte de payer les criminels.

5. COMMUNIQUER : Un seul porte-parole officiel ; appliquer les notifications CNIL / ANSSI.

4. Comment Présenter ce Projet à Votre Chef Demain

Voici le script et le plan d'action recommandé pour faire une démonstration de 5 minutes qui convaincra immédiatement votre chef de département :

Étape 1 - L'Accroche (30 secondes)

« Monsieur le Directeur, plutôt que de faire une énième vidéo de sensibilisation que les gens regardent d'un œil distrait, j'ai développé une véritable plateforme d'entraînement immersive : **Meridian Cyber Defense OS**. Elle simule exactement ce que nos collaborateurs et nos équipes IT vivent lors d'une attaque réelle, sur nos vrais outils. Je vous montre en 3 minutes comment ça fonctionne. »

Étape 2 - La Démonstration du Mode Démo Auto (2 minutes)

1. Ouvrez `http://localhost:5173/simulation`.
2. Cliquez sur le bouton rouge : [**DÉMO AUTO (SANS SCROLL)** →].
3. Dites à votre chef : « Regardez, vous n'avez même pas besoin de toucher la souris. La plateforme explique d'abord à la salle ce qui va se passer avec le Triple Regard (Salarié, Hacker, SOC), puis bascule automatiquement dans l'outil réel pour montrer l'exécution en direct. »
4. Laissez défiler l'étape Outlook, puis Splunk, puis le radar réseau, et Windows Server avec le rançongiciel.

💡 LES 4 ARGUMENTS D'AUTORITÉ À METTRE EN AVANT :

1. Sécurité & Souveraineté : L'application tourne 100% en local, sans dépendance externe, sans fuite de données.

3. Trois Espaces Complémentaires : Espace Entreprise (outils), Projection Salle (16:9 avec votes), et Cockpit Formateur.

2. Barème ANSSI Validé : Attribue des points positifs pour les bons réflexes (+2, +3) et sanctionne les erreurs (-2, -3).

4. Fiche A4 Imprimable : Exportable immédiatement en JSON/CSV et fiches de synthèse pour les participants.

Étape 3 - La Conclusion Gagnante

« Cette solution est prête immédiatement. Elle valorise notre département de cybersécurité en proposant un standard de niveau international inspiré d'OffSec, tout en étant parfaitement accessible à l'ensemble des métiers de l'entreprise. »

COMMANDE DE DÉMARRAGE RAPIDE :

`npm run dev → http://localhost:5173/simulation`